

SOC 2

1. Overview

SOC 2 (System and Organization Controls 2) is a **voluntary attestation framework**, developed by the American Institute of Certified Public Accountants (AICPA), specifically designed for **service organizations** — companies that provide services (particularly technology and cloud services) to other businesses and need to demonstrate the trustworthiness of their internal controls to those customers. Unlike a fixed checklist standard, SOC 2 evaluates an organization's controls against a set of criteria the organization itself selects, and the output is not a pass/fail "certification" but an **audit report** produced by an independent CPA firm.

Property	Detail
Type	Voluntary attestation framework
Maintained by	AICPA (American Institute of Certified Public Accountants)
Evaluated against	The AICPA's Trust Services Criteria
Output	An independent auditor's attestation report (not a certificate)
Who pursues it	Service organizations (especially SaaS/cloud providers) needing to demonstrate control trustworthiness to customers

2. The Trust Services Criteria

SOC 2 audits are conducted against the **Trust Services Criteria (TSC)**, five categories of controls — though only the first is mandatory for every SOC 2 report:

Criterion	Mandatory?	Focus
Security	Always required (the "Common Criteria")	Protection against unauthorized access, both physical and logical
Availability	Optional, selected as relevant	System availability for operation and use as committed/agreed
Processing Integrity	Optional, selected as relevant	System processing is complete, valid, accurate, timely, and authorized

Criterion	Mandatory?	Focus
Confidentiality	Optional, selected as relevant	Information designated as confidential is protected as committed/agreed
Privacy	Optional, selected as relevant	Personal information is collected, used, retained, disclosed, and disposed of in conformity with the organization's privacy notice

An organization selects which of the optional four criteria are relevant to its specific service offering, in addition to the always-mandatory Security criterion — meaning, similar to ISO 27001's Statement of Applicability, the exact scope of what's actually assessed varies meaningfully between different organizations' SOC 2 reports.

3. Type I vs. Type II Reports

This distinction is one of the most important and frequently misunderstood aspects of SOC 2:

	SOC 2 Type I	SOC 2 Type II
What it assesses	Whether controls are suitably designed as of a specific point in time	Whether controls are suitably designed and operating effectively over a sustained period
Time period	A single point-in-time snapshot	An observation period, typically 6–12 months
What it actually proves	Controls exist on paper/in design	Controls were genuinely, consistently operated as designed, with tested evidence over time
Relative rigor	Lower — easier and faster to obtain	Higher — the report most customers and partners genuinely value

A Type I report can be obtained relatively quickly and demonstrates initial control design, but a **Type II report is what most sophisticated customers and partners actually expect** to see, since it demonstrates sustained operational effectiveness rather than a one-time snapshot — directly connecting to the Compliance vs. Security guide's point about point-in-time assessments being inherently limited.

4. Type 1 and Type 2 — Report Structure

A SOC 2 report itself is a substantial, detailed document, typically including:

- **Management's assertion** — the organization's own description of its system and controls.
- **Independent auditor's opinion** — the CPA firm's formal opinion on whether the controls are fairly presented and (for Type II) operating effectively.
- **Description of the system** — detailed description of the service organization's infrastructure, software, people, procedures, and data relevant to the audited criteria.
- **Description of tests of controls and results** (Type II specifically) — the actual testing methodology and outcomes for each control.

Because these reports are detailed and often contain sensitive internal security information, they are typically shared under NDA directly with prospective/existing customers rather than published publicly (unlike, for instance, a public certification badge).

5. Who Conducts the Audit

SOC 2 audits must be performed by a **licensed CPA firm** (though the actual fieldwork is frequently performed by information security specialists working under the CPA firm's oversight and issuing the formal opinion) — this is a defining structural feature, since SOC 2 originates from AICPA's accounting/attestation standards framework rather than a pure information-security standards body.

6. SOC 1 vs. SOC 2 vs. SOC 3 — Avoiding Confusion

Report	Focus	Audience
SOC 1	Controls relevant to a customer's financial reporting (e.g., a payroll processor's controls affecting client financial statements)	Auditors of the customer's own financial statements
SOC 2	Controls relevant to security, availability, processing integrity, confidentiality, and privacy (the Trust Services Criteria)	Customers, partners, and prospects evaluating the service organization's operational trustworthiness

Report	Focus	Audience
SOC 3	A general-use, less detailed summary version of a SOC 2 report	General public — suitable for public marketing/website use, unlike the detailed SOC 2 report itself

7. Why Organizations Pursue SOC 2

- **Sales enablement** — increasingly a baseline requirement in enterprise B2B sales cycles, particularly for SaaS and cloud service providers; prospective customers' own security/procurement teams frequently require a current SOC 2 Type II report before finalizing a contract.
- **Reduces redundant customer audits** — a single, independently produced report substitutes for many individual customers each wanting to conduct their own security assessment of the vendor.
- **Market differentiation** — signals security maturity to a market where SOC 2 has become a widely recognized baseline expectation, particularly in the U.S. technology sector.

8. Common Real-World Compliance Gaps

- Relying on a Type I report alone for an extended period, when customers/partners increasingly expect Type II.
- Selecting an overly narrow set of Trust Services Criteria that doesn't actually reflect the service's real risk profile, potentially raising questions during customer due diligence.
- Treating the audit period as the only time controls need to genuinely operate as designed, rather than maintaining them continuously (directly the "compliance theater" failure pattern described in the Compliance vs. Security guide).
- Poor mapping between the system description provided to auditors and the actual, current production environment, especially in fast-changing technology organizations.
- Underestimating the audit evidence-collection burden — Type II audits require substantial, consistent evidence gathering throughout the entire observation period, not just preparation immediately before the audit.

9. Summary

SOC 2 is a voluntary, AICPA-governed attestation framework specifically suited to demonstrating a service organization's control trustworthiness to business customers, built around the Trust Services Criteria (with Security mandatory and four additional criteria selected as relevant). Its Type I vs. Type II distinction — point-in-time design assessment versus sustained operational-effectiveness testing over an extended period — is the single most consequential structural detail to understand, since a Type II report is what genuinely demonstrates ongoing control effectiveness rather than a one-time snapshot, making it the far more meaningful signal for customers and partners evaluating a vendor's actual security posture.